

Metodologías de Pruebas de Penetración

Las metodologías de pruebas de penetración son marcos estructurados que guían la identificación, análisis y explotación controlada de vulnerabilidades en sistemas informáticos. Su objetivo principal es simular ataques reales para evaluar el nivel de seguridad de una organización. Entre las metodologías más utilizadas destacan MITRE ATT&CK, NIST SP 800-115, OSSTMM y OWASP.

Metodología	Enfoque Principal	Fases Clave	Ventajas	Desventajas
MITRE ATT&CK	Base de conocimiento de tácticas y técnicas de adversarios	Recopilación, mapeo de comportamiento, análisis de amenazas	Muy detallada, basada en eventos reales del mundo	No es un proceso secuencial de pentesting tradicional
NIST SP 800-115	Guía formal de evaluación de seguridad de redes y sistemas	Planificación, descubrimiento, ataque, reporte	Enfoque estructurado, oficial y estandarizado	Menos práctico para principiantes
OSSTMM	Seguridad operativa y medición objetiva de la confianza	Recolección de datos, análisis, pruebas, reporte	Muy detallada y cuantificable	Compleja de aplicar
OWASP	Seguridad en aplicaciones web y servicios asociados	Reconocimiento, pruebas de vulnerabilidades, explotación	Ideal para aplicaciones web	Limitada fuera del entorno web

- MITRE ATT&CK: Es una base de conocimiento accesible globalmente que detalla las tácticas, técnicas y procedimientos (TTPs) utilizados por los ciberdelincuentes basándose en observaciones del mundo real, permitiendo modelar amenazas y mejorar la detección defensiva.
- NIST SP 800-115: Es una guía técnica de la National Institute of Standards and Technology diseñada para ayudar a las organizaciones a planificar, realizar y documentar evaluaciones de seguridad y pruebas de penetración en redes y sistemas de forma estandarizada.
- OSSTMM (Open Source Security Testing Methodology Manual): Es un estándar riguroso enfocado en la seguridad operativa y la validación científica de la confianza a través de métricas objetivas y metodologías de prueba cuantificables.
- OWASP (Open Web Application Security Project): Es un marco y comunidad dedicada a la seguridad del software, enfocada especialmente en identificar y mitigar vulnerabilidades críticas en aplicaciones web y servicios en la nube.